

Table of Contents

Estado de revisión: Borrador de traducción asistida por máquina. Requiere revisión humana de terminología, significado, enlaces, formato y vigencia técnica antes de marcarse como edición final.

CYBERSECURITY, PRIVACY & COMPLIANCE SERIES

CIS Controles de Seguridad Crítica v8.1

**** Aplicación práctica, medición, evidencia y herramientas de código abierto****

Un manual de trabajo para administradores, analistas junior, estudiantes, cambiadores de carrera, asesores y equipos de seguridad

Alberto (Al) Leiva

Primera edición • Julio 2026

Silencio **Inside:** 18 Controles • 153 Salvaguardias • IG1, IG2, IG3 • medición • evidencia • herramientas • manual de gestión • laboratorios • preparación de la carrera Silencio...

Publication and Use Notice

Autor: Alberto (Al) Leiva

Edición: Primera edición, Julio 2026

Este manual educativo independiente no es un Centro para la publicación, certificación, acreditación, informe de auditoría, opinión legal o garantía de seguridad o cumplimiento. Controles CIS y CIS Los parámetros son marcas comerciales del Centro de Seguridad de Internet. Utilice los recursos oficiales CIS para el contenido exacto y la orientación actual.

Los controles CIS son las mejores prácticas de ciberseguridad. No reemplazan las leyes, reglamentos, contratos, requisitos sectoriales, evaluación de riesgos o responsabilidad de gestión aplicables. Un mapeo muestra relaciones; no prueba automáticamente el cumplimiento de otro marco.

Uso ético y autorizado

Utilice herramientas técnicas únicamente en activos, redes, aplicaciones, cuentas de nube, repositorios y datos que posee o está específicamente autorizado por escrito para evaluar. Use información sintética y sistemas aislados en laboratorios.

Prefacio

Una introducción práctica para priorizar la defensa cibernética y la medición basada en evidencia.

Los Controles CIS convierten las necesidades defensivas comunes en salvaguardias focalizadas. Su fuerza es la priorización práctica: saber lo que posee, controlar software y datos, asegurar configuraciones e identidades, gestionar vulnerabilidades y registros, prepararse para perturbaciones y ataques, y probar si las defensas funcionan.

La versión 8.1 es la edición actual. Se trata de una actualización iterativa al v8 que realineó mappings to NIST CSF 2.0, definiciones ampliadas de plazo reserva, clases de activos revisados y cartografías de Salvaguardia, problemas menores corregidos, aclarar algunas Salvaguardias, e incorporar la función de seguridad de Govern en las cartografías. Los 18 Controles y 153 Salvaguardias siguen siendo la estructura central.

Una instalación de herramientas no es la implementación. La aplicación efectiva requiere un alcance definido, poblaciones completas, configuración segura, pruebas operativas, propietarios capacitados, manejo de excepciones, medición, corrección y retesting. Los administradores deciden prioridades y recursos; los analistas hacen que esas decisiones sean fiables mediante inventarios y pruebas precisos.

Cómo utilizar este manual

- Los administradores deben comenzar con los Capítulos 1-5 y 24–25.
- Los analistas juniores deben estudiar los 18 capítulos de Control, método de medición, herramientas, laboratorio y capítulo de entrevista.
- Los equipos técnicos deben conectar cada Salvaguardia a activos, datos, propietarios, procedimientos, configuración, monitoreo, manejo de excepciones y pruebas.
- Los evaluadores deben utilizar la Evaluación oficial de Controles CIS Especificación de insumos, operaciones, medidas, métricas, suposiciones y exámenes de procedimiento.

Contenido de la palabra:** Este documento contiene un campo de mesa de contenido de Word nativo. La guía del capítulo contendrá números de página verificados para esta edición. Después de editar, haga clic con el botón derecho en el contenido y elija el campo de actualización, luego actualice la tabla completa. Silencio.

Tabla de contenidos

[Notificación de publicación y uso \[2\]\(#publication-and-use-notice\)](#)

[Uso electrónico y autorizado \[2\] \(#ethical-and-authorized-use\)](#)

[Prefacio \[3\] \(#preface\)](#)

[Cómo utilizar este manual \[4\]\(#how-to-use-this-manual\)](#)

Tabla de contenidos [4](#table-of-contents)

1. CIS Controls v8.1 Foundations [7](#cis-controls-v8.1-foundations)

2. Grupos de aplicación y prioridades [8](#implementation-groups-and-prioritization)

3. Gobernanza, alcance y propiedad [9](#governance-scope-and-ownership)

4. Medición con la Evaluación de CIS Especificación [10](#measurement-with-the-cis-assessment-specification)

5. Implementation Roadmap [11](#implementation-roadmap)

6. Control 1 - Inventario y Control de Activos Empresarios [12](#control-1-inventory-and-control-of-enterprise-assets)

7. Control 2 — Inventario y control de activos de software [13](#control-2-inventory-and-control-of-software-assets)

8. Control 3 — Data Protection [14](#control-3-data-protection)

9. Control 4 — Configuración segura de activos y software de la empresa [16](#control-4-secure-configuration-of-enterprise-assets-and-software)

10. Control 5 — Account Management [18](#control-5-account-management)

11. Control 6 — Access Control Management [19](#control-6-access-control-management)

12. Control 7 - Gestión continua de la vulnerabilidad [21](#control-7-continuous-vulnerability-management)

13. Control 8 — Audit Log Management [23](#control-8-audit-log-management)

14. Control 9 — Email and Web Browser Protections [24](#control-9-email-and-web-browser-protections)

15. Control 10 — Malware Defenses [25](#control-10-malware-defenses)

16. Control 11 — Data Recovery [26](#control-11-data-recovery)

17. Control 12 — Network Infrastructure Management [27](#control-12-network-infrastructure-management)

18. Control 13 — Network Monitoring and Defense [28](#control-13-network-monitoring-and-defense)

19. Control 14 — Security Awareness and Skills Training [30](#control-14-security-awareness-and-skills-training)

20. Control 15 — Service Provider Management [31](#control-15-service-provider-management)

21. Control 16 — Application Software Security [32](#control-16-application-software-security)

22. Control 17 — Gestión de la respuesta de incidentes [34] (#control-17-incident-response-management)

23. Control 18 — Penetration Testing [36](#control-18-penetration-testing)

24. Open-Source Tools [37](#open-source-tools)

24.1 CIS Controls Navigator [37](#cis-controls-navigator)

24.2 CIS Controls Assessment Specification [37](#cis-controls-assessment-specification)

24.3 CIS-CAT Lite [37](#cis-cat-lite)

24.4 CISO Assistant [38](#ciso-assistant)

24.5 Wazuh [38](#wazuh)

24.6 osquery [38](#osquery)

24.7 OpenSCAP [38](#openscap)

24.8 Lynis [38](#lynis)

24.9 Nmap [39](#nmap)

24.10 Greenbone Community Edition [39](#greenbone-community-edition)

24.11 Trivy [39](#trivy)

24.12 OWASP ZAP [39](#owasp-zap)

24.13 Suricata [39](#suricata)

24.14 Keycloak [39](#keycloak)

24.15 DefectDojo [40](#defectdojo)

24.16 Velociraptor [40](#velociraptor)

25. El CIS Controls Playbook [41](#managers-cis-controls-playbook)

26. Guía de la carrera de analista junior [42](#junior-analyst-career-guide)

26.1 Trabajo junior típico [42](#typical-junior-work)

27. Laboratorio de Ficción y Cartera [44](#fictional-laboratory-and-portfolio)

28. Plan de aprendizaje de 30 días [45] (#thirty-day-learning-plan)

29. Preparación de entrevistas [46](#interview-preparation)

29.1 ¿Cuáles son los controles CIS? [46](#what-are-the-cis-controls)

29.2 ¿Qué es IG1? [46](#what-is-ig1)

29.3 ¿Se ajusta IG1 a cada requisito? [46](#does-ig1-fit-every-requirement)

29.4 ¿Cómo mide una Salvaguardia? [46](#how-do-you-measure-a-safeguard)

29.5 ¿Por qué son importantes los inventarios? [46](#why-are-inventories-important)

29.6 Vulnerability scan versus penetración test? [46](#vulnerability-scan-versus-penetration-test)

29.7 ¿Una asignación marco demuestra el cumplimiento? [46](#does-a-framework-mapping-prove-compliance)

29.8 ¿Qué puede concluir un analista junior? [46](#what-can-a-junior-analyst-conclude)

29.9 Preguntas para hacer al empleador [46](#questions-to-ask-the-employer)

30. Plantillas, Glosario, Índice y Referencias [48](#templates-glossary-index-and-references)

30.1 Documentos de trabajo de medición de seguridad [48](#safeguard-measurement-workpaper)

30.2 Registro de búsqueda y prueba [48](#finding-and-retest-record)

30.3 Glosario [48](#glossary)

30.4 Índice de asunto [49](#subject-index)

30.5 Referencias oficiales [49](#official-references)

1. Controles CIS v8.1 Fundaciones

La versión actual, estructura, propósito y limitaciones.

“El control organiza 153 Salvaguardias en un programa defensivo práctico” (Nota: 3.94164in”
alt=“Los controles organizan 153 Salvaguardias en un programa defensivo práctico.” /

Figura 1. Los 18 controles de seguridad críticos CIS

- CIS Controls v8.1 fue publicado en junio de 2024 y sigue siendo la edición actual a partir de julio de 2026.
- Los Controles se priorizan las mejores prácticas diseñadas para defender sistemas y redes contra ataques frecuentes.
- El marco contiene 18 Controles y 153 Salvaguardias.
- Las salvaguardias se refieren a las clases de activos, las funciones de seguridad y los grupos de aplicación.
- La versión 8.1 alinea su cartografía NIST CSF a CSF 2.0 e incluye cartografías Govern.
- Existen mapas oficiales para múltiples marcos, pero la aplicación debe verificarse por separado para cada requisito aplicable.

Silencio **Layer** Silencio... Silencio Control Silencio Resultado defensivo amplio, como inventario de activos o respuesta a incidentes — Salvaguardia Silencio Acción focalizada que puede ser

asignada, implementada y medida Silencio Clase de activos Silencio Tipo de tema afectado, tales como dispositivos, software, datos, red, usuarios o documentación Función de seguridad permanente – Govern, Identificar, Proteger, Detectar, Responder o Recuperar la cartografía Silencio Grupo de Aplicación Silencio Priorización recomendada basada en el perfil de riesgo y los recursos Medida de evaluación de la vida útil Entradas, operaciones, medidas, métricas y revisión de procedimientos utilizados para evaluar una salvaguardia sometida

2. Grupos de aplicación y prioridades

Cómo IG1, IG2, y las organizaciones de ayuda IG3 eligen un punto de partida realista.

■img src="media/image2.png" estilo="Ancho:6.15in; Altura:3.39605in" alt="Cada grupo se construye sobre el grupo anterior; IG3 contiene todas las Salvaguardias." /

Gráfico 2 Progresión del Grupo de Aplicación

Silencio **La situación física** Silencioso** Silencio

----- Silencio IG1 Silencio 56 Silencio Recursos de seguridad limitados y experiencia; menor sensibilidad; alta necesidad de continuidad básica Silencio Esencial de la higiene cibernética contra ataques comunes Silencio IG2 Silencio IG1 + 74 Silencio Múltiples departamentos, mayor complejidad, información sensible y dependencia más operativa Silencio Gestionar mayor riesgo y complejidad operacional Silencio IG3 Silencio IG1 + IG2 + 23 = 153 Silencio Especialistas en seguridad, datos confidenciales o regulados, servicios críticos y amenazas sofisticadas Silencio Reducir el impacto de ataque apuntado y avanzado

- Cada empresa debe comenzar con IG1 según la orientación CIS.
- Seleccione un IG considerando la sensibilidad de los datos, los servicios críticos, la exposición a amenazas, las obligaciones jurídicas y contractuales, la tolerancia empresarial, la tecnología, la dotación de personal y los conocimientos especializados.
- Un IG es una ayuda de priorización, no permiso para ignorar un riesgo material o requisito obligatorio.
- Adiciones, secuencias, excepciones, aceptación de riesgos, propietarios y fechas.
- Utilice el navegador oficial de control CIS para filtrar v8.1 Salvaguardias y mapas de revisión.

3. Gobernanza, alcance y propiedad

La base de gestión necesaria para que las Salvaguardias funcionen de forma sistemática.

- Definir los objetivos institucionales, los servicios críticos, los datos confidenciales, las obligaciones jurídicas y contractuales, el perfil de amenazas, la tolerancia al riesgo y el Grupo de Aplicación elegido.

- Crear inventarios completos para activos empresariales, software, datos, cuentas, sistemas de autenticación, infraestructura de red, registros, proveedores, aplicaciones y recursos de recuperación.
- Assign one accountable owner for each Safeguard and operational owners for each affected platform or process.
- Definir el alcance, la aplicabilidad, las dependencias, las responsabilidades del proveedor de servicios, las excepciones permitidas, la autoridad de aprobación y los desencadenantes de revisión.
- Planificar financiación, personas, habilidades, tecnología, tiempo y gestión del cambio.
- Definir las métricas y la presentación de informes antes de la aplicación para que la cobertura y el fracaso sean visibles.
- Operar un ciclo de gobernanza: priorizar, implementar, medir, corregir, retestar y mejorar.

Silencio **Role** Silencio **Decisión o responsabilidad** Silencio... — Patrocinador ejecutivo
 Silencioso Dirección, tolerancia al riesgo, financiación, escalada y rendición de cuentas
 Silencioso Propietario de control Silencio Diseño de salvaguardias, alcance, procedimiento, medición, excepciones y mejora Silencio Asset o propietario de servicio Silencio Inventario exacto, uso aprobado, configuración, impacto de negocios y remediación TENAS Operaciones de seguridad TENIDO Monitoreo, alerta, investigación, respuesta y evidencia TEN IT / Engineering TENIDO Implementación, control de cambio, parche, configuración y recuperación TEN GRC / Analyst ANTE Mapping, evidencia, medición, hallazgos, seguimiento de la acción y reportaje TENIDO tención Auditoría interna / evaluador tención Servicio prestado Silencio Controles, pruebas, incidentes, cambios y soporte de salida

4. Medición con la especificación de evaluación CIS

Un método repetible para decidir si se aplican salvaguardias.

<img src="media/image3.png" estilo="width:6.15in;height:2.87986in" alt= "La especificación oficial pasa de los datos definidos a las operaciones, medidas, métricas y revisión de procedimiento." /

Gráfico 3 CIS Estructura de medición de salvaguardias

Silencio** Element** Silencioso** Silencio... metadatos de salvaguardia permanente ¿Cuál es la salvaguardia exacta, clase de activos, función de seguridad y IG? TENIENTES DE LAS CUOTAS ¿Qué otras Salvaguardias o poblaciones deben existir primero? ¡ Asunciones Silencio ¿Qué condición aceptada afecta la medición? Silencio ¿Qué datos completos y fiables se requieren? Silencio ¿Qué análisis se debe realizar en las entradas? Silencio Silencio ¿Qué cuentas, listas, fechas, configuraciones o resultados resultan? TENCIÓN FORMULADA ¿Cómo se calculan e interpretan las medidas? ¿Existe un proceso documentado e incluye elementos necesarios? Silencio

- Definir la salvaguardia exacta y la población abarcada.
- Obtenga los insumos necesarios y valide la integridad, precisión, tiempo, propiedad y fiabilidad de la fuente.
- Siga las operaciones oficiales de medición o documente un método fiable equivalente.
- Retener cálculos de medida y la población de excepción subyacente, no sólo un porcentaje.
- Evaluar si se implementa la Salvaguardia y qué tan bien funciona.
- Asignar una corrección para la cobertura perdida, mala configuración, revisión atrasada, excepciones o datos poco fiables.
- Retesta utilizando los mismos criterios y la población refrescante.
- Report scope, result, exception, limitation, owner, action, and date.

5. Aplicación de la hoja de ruta

Una secuencia práctica de los inventarios a la resiliencia probada.

1. Elija y documente el Grupo de Aplicación inicial y cualquier adición necesaria.
2. Construir y reconciliar las poblaciones principales: activos, software, datos, cuentas, sistemas de autenticación, red, proveedores, aplicaciones y registros.
3. Aplicar las salvaguardias IG1 con los propietarios, procedimientos, métricas de cobertura, excepciones y pruebas.
4. Identidades seguras, configuraciones, vulnerabilidades, correo electrónico, navegadores, defensas de malware, respaldos y monitoreo esencial.
5. Respuesta y recuperación de incidentes de ejercicio antes de una emergencia real.
6. Medir todas las salvaguardias aplicables utilizando insumos fiables y operaciones repetibles.
7. Cobertura incompleta y fallos repetidos; verificar las correcciones mediante el replanteamiento.
8. Ampliar hacia IG2 o IG3 sobre la base de riesgos, obligaciones, madurez y exposición a amenazas.
9. Utilizar mapas oficiales para coordinar otros marcos sin tratar las asignaciones como cumplimiento automático.

tención **Principio de aplicación:** Un grupo más pequeño de Salvaguardias que es totalmente abarcado, operado, medido y mejorado es más defensible que una larga lista marcada completa sin pruebas fiables. Silencio Silencio.

6. Control 1 - Inventario y Control de Activos Empresarios

Las 5 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

■img src="media/image4.png" style="width:6.15in;height:3.38991in" alt="Descubrimiento, reconciliación, respuesta y revisión mantienen a las poblaciones fundacionales actuales."

Figure 4. Asset and software inventory cycle

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para el inventario y el control de los activos institucionales. Silencio Silencio...

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** La vida

————— Silencio 1.1
Silencio Establecer y Mantener Inventario de Activos Empresarios detallados Silencio Poner en marcha un proceso de repetibilidad, propiedad o control técnico para establecer y mantener inventario de activos institucionales detallados, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de activos, propietarios, estado de aprobación, descubrimiento activo/pasivo, registros DHCP/IPAM, entradas de activos no autorizados TEN Silencio 1.2 Silencio Dirección Activos no autorizados Ponga en marcha un proceso repetible, de propiedad o control técnico para abordar los activos no autorizados, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de activos, propietarios, estado de aprobación, descubrimiento activo/pasivo, registros DHCP/IPAM, entradas de activos no autorizados TEN Silencio 1.3 Silencio Utilizar una herramienta de descubrimiento activo Ponga en marcha un proceso repetible, de propiedad o control técnico para utilizar una herramienta Active Discovery, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de activos, propietarios, estado de aprobación, descubrimiento activo/pasivo, registros DHCP/IPAM, entradas de activos no autorizados TEN Silencio 1.4 Silencio Uso DHCP Iniciar sesión para actualizar Inventario de Activos Empresarios Silencio Ponga en marcha un proceso repetible, propiedad o control técnico para utilizar DHCP Logging para actualizar Inventario de Activos Empresarios, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección

y retest. inventario de activos, propietarios, estado de aprobación, descubrimiento activo/pasivo, registros DHCP/IPAM, entradas de activos no autorizados TEN Ø 1.5 Ø Utilizar una herramienta de descubrimiento de activos pasivos Ponga en marcha un proceso repetible, de propiedad o control técnico para utilizar una herramienta Passive Asset Discovery Tool, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de activos, propietarios, estado de aprobación, descubrimiento activo/pasivo, registros DHCP/IPAM, entradas de activos no autorizados TEN

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

7. Control 2 - Inventario y control de activos de software

Las 7 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para el inventario y el control de los activos informáticos. Silencio Silencio...

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** Silencio

———— TEN 2.1 TENIDO Establecer y mantener un inventario de software TENIDO Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener un inventario de software, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de software, estado de apoyo, lista aprobada, resultados de descubrimientos, excepciones, políticas de habilitación y eventos Silencio 2.2 Silencio Garantizar que el Software Autorizado está actualmente respaldado Silencio Ponga en marcha un proceso repetible, de propiedad o control técnico para asegurar que el Software Autorizado esté actualmente respaldado, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de software, estado de apoyo, lista aprobada, resultados de descubrimientos, excepciones, políticas de habilitación y eventos Silencio 2.3 Silencio Dirección Software no autorizado Ponga en marcha un proceso repetible, de propiedad o control técnico para abordar el software no autorizado, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de software, estado de apoyo, lista aprobada, resultados de descubrimientos, excepciones, políticas de habilitación y eventos Silencio 2.4 Silencio Utilizar herramientas de inventario de software automatizado Ponga en

TENIDO Establecer y mantener un proceso de gestión de datos TENIDO Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener un proceso de gestión de datos, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido,

población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso TEN 3.2 TENIDO Establecer y mantener un inventario de datos ANTEPóngase en marcha un proceso repetible, de propiedad o control técnico para establecer y mantener un inventario de datos, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso Silencio 3.3 Silencio Configurar Listas de control de acceso de datos Ponga en marcha un proceso repetible, de propiedad o control técnico para configurar listas de control de acceso de datos, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso TEN 3.4 TENCIÓN DE LOS RECURSOS DE EJECUCIÓN DE LOS Datos TENIENTES Ponga en marcha un proceso repetible, de propiedad o control técnico para hacer cumplir la Retención de Datos, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso TENCIÓN 3.5 TENIENDO EL DISPONIBLE DE LOS Datos Ponga en marcha un proceso repetible, de propiedad o control técnico para disponer de datos de forma segura, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso tención 3.6 – Encrypt Data on End-User Devices tención Ponga en marcha un proceso repetible, de propiedad o control técnico para cifrar datos sobre dispositivos de usuario final, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso Silencio 3.7 Silencio Establecer y mantener un plan de clasificación de datos Silencio Poner en marcha un proceso de repetición, propiedad o control técnico para establecer y mantener un plan de clasificación de datos, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso Silencio 3.8 Silencio Document Data Flows Silencio Ponga en marcha un proceso repetible, de propiedad o control técnico para documentar los flujos de datos, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso TEN 3.9 TENIDO Datos de cifrado en medios extraíbles ANTEPonga un proceso repetible, de propiedad o control técnico en su lugar para cifrar datos en medios extraíbles, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso Silencio 3.10 Silencio Encrypt Sensitive Data in Transit – Ponga en marcha un proceso repetible, de propiedad o control técnico para cifrar datos sensibles en tránsito, a continuación, verifique cobertura y excepciones. tención Confirme

alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso Silencio 3.11 Silencio Encrypt Sensitive Data At Rest Ponga en marcha un proceso repetible, de propiedad o control técnico para cifrar datos sensibles en reposo, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso Silencio 3.12 Silencio Segment Data Processing and Storage Based on Sensitivity TEN Poner en marcha un proceso repetible, de propiedad o control técnico para segmentar el procesamiento de datos y almacenamiento basado en la sensibilidad, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso Silencio 3.13 Silencio Implementar una solución de prevención de la pérdida de datos Ponga en marcha un proceso repetible, de propiedad o control técnico para desplegar una solución de prevención de la pérdida de datos, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso Silencio 3.14 Silencio Log Sensitive Data Access Ponga en marcha un proceso repetible, de propiedad o control técnico para registrar el acceso de datos sensibles, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

9. Control 4 — Configuración segura de activos y software empresarial

Las 12 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la configuración segura de los activos y programas institucionales. Silencio Silencio...

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** La vida

de configuración segura – Poner en marcha un proceso repetible, de propiedad o control técnico para establecer y mantener un proceso de configuración segura, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil Ø 4.2 tención Establecer y mantener un proceso de configuración segura para infraestructura de red – Poner en marcha un proceso repetible, de propiedad o control técnico para establecer y mantener un proceso de configuración segura para infraestructura de red, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil Silencio 4.3 Silencio Configure Automatic Session Locking on Enterprise Assets – Ponga en marcha un proceso repetible, de propiedad o control técnico para configurar el bloqueo automático de sesión en activos empresariales, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil Silencio 4.4 – Implementar y administrar un cortafuegos en servidores – Poner en marcha un proceso repetible, de propiedad o control técnico para implementar y administrar un cortafuegos en servidores, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil Silencio 4.5 – Implementar y administrar un cortafuegos en dispositivos de usuario final – Poner en marcha un proceso repetible, de propiedad o control técnico para implementar y administrar un cortafuegos en dispositivos de usuario final, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil Silencio 4.6 Silencio Gestionar de forma segura los activos y el software de la empresa – Poner en marcha un proceso repetible, propiedad o control técnico para gestionar de forma segura los activos y software de la empresa, a continuación, verificar la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de

referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil Silencio 4.7 Silencio Manage Default Accounts on Enterprise Assets and Software tención Ponga en marcha un proceso repetible, de propiedad o control técnico para gestionar Cuentas Predeterminadas en Activos y Software Empresarial, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil Silencio 4.8 Silencio Desinstalar o desactivar servicios innecesarios en activos y software de la empresa Silencio Ponga un proceso repetible, propiedad o control técnico en su lugar para desinstalar o desactivar servicios innecesarios en activos y software de la empresa, a continuación, verifique la cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil Silencio 4.9 Silencio Configure Trusted DNS Servers on Enterprise Assets tención Ponga en marcha un proceso repetible, de propiedad o control técnico para configurar Trusted DNS Servers on Enterprise Assets, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil Silencio 4.10 Ø Enforce Automatic Device Lockout on Portable End-User Devices Ponga en marcha un proceso repetible, de propiedad o control técnico para hacer cumplir el bloqueo automático de dispositivos en dispositivos portátiles de usuario final, a continuación, verifique la cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil Silencio 4.11 Silencio Enforce Remote Wipe Capability on Portable End-User Devices Ponga en marcha un proceso repetible, de propiedad o control técnico para hacer cumplir la Capacidad de Wipe remota en dispositivos portátiles de usuario final, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil Silencio 4.12 – Espacios de trabajo para empresas separadas en dispositivos móviles de usuario final TENIENDO un proceso repetible, de propiedad o control técnico en el lugar para separar espacios de trabajo empresariales en dispositivos móviles de usuario final, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

Control 5 - Gestión de Cuentas

Todas las 6 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la gestión de las cuentas. Silencio Silencio.

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** Silencio

----- Silencio 5.1 Silencio Establecer y mantener un inventario de cuentas Silencio Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener un inventario de cuentas, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. poblaciones, propietarios, fechas, política de contraseñas, acciones de cuenta inactiva, inventarios de administración y de cuenta de servicios TEN 5.2 TENIDO Use Contraseñas Únicas ANTEPóngase en marcha un proceso repetible, de propiedad o control técnico para usar Contraseñas Únicas, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. poblaciones, propietarios, fechas, política de contraseñas, acciones de cuenta inactiva, inventarios de administración y de cuenta de servicios Silencio 5.3 Silencio Cuentas de Dormant Desactivados Ponga en marcha un proceso repetible, de propiedad o control técnico para deshabilitar Cuentas Dormant, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. poblaciones, propietarios, fechas, política de contraseñas,

acciones de cuenta inactiva, inventarios de administración y de cuenta de servicios tención 5.4 Silencioso Administrador de Restricciones Privilegios a Cuentas Administradoras Dedicadas Poner en marcha un proceso repetible, de propiedad o control técnico para restringir los privilegios del Administrador a las Cuentas de Administrador Dedicado, a continuación, verificar la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. poblaciones, propietarios, fechas, política de contraseñas, acciones de cuenta inactiva, inventarios de administración y de cuenta de servicios TEN 5.5 TENIDO Establecer y mantener un inventario de cuentas de servicio TENIDO Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener un inventario de cuentas de servicio, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. poblaciones, propietarios, fechas, política de contraseñas, acciones de cuenta inactiva, inventarios de administración y de cuenta de servicios Silencio 5.6 Silencio Centralizar Gestión de Cuentas Poner en marcha un proceso repetible, de propiedad o control técnico para centralizar la gestión de cuentas, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. poblaciones, propietarios, fechas, política de contraseñas, acciones de cuenta inactiva, inventarios de administración y de cuenta de servicios

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

11. Control 6 — Access Control Management

Las 8 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

‘img src=“media/image6.png” style=“width:6.15in;height:3.03192in” alt=“Las cuentas y privilegios requieren la creación aprobada, la autenticación fuerte, la revisión y la revocación oportuna”.

Gráfico 6 Identidad y acceso ciclo de vida

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la gestión del control del acceso. Silencio Silencio...

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** Silencio

----- TEN 6.1 TEN Establezca un proceso de concesión de acceso TENIDO Ponga en marcha un proceso repetible, de propiedad o control técnico para establecer un proceso de concesión de acceso, a continuación, verifique la

cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Entradas de subvención/revocación, cobertura del MFA, inventario del sistema de autenticación, funciones, derechos y exámenes de acceso Silencio 6.2 Silencio Establezca un proceso de revocación de acceso Silencio Ponga en marcha un proceso de repetición, propiedad o control técnico para establecer un proceso de revocación de acceso, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Entradas de subvención/revocación, cobertura del MFA, inventario del sistema de autenticación, funciones, derechos y exámenes de acceso TEN 6.3 TENIDO Require MFA for Externally-Exposed Applications TEN Ponga en marcha un proceso repetible, de propiedad o control técnico para requerir MFA para Aplicaciones Expuestas Externamente, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Entradas de subvención/revocación, cobertura del MFA, inventario del sistema de autenticación, funciones, derechos y exámenes de acceso Silencio 6.4 Silencio Requiere MFA para el acceso a redes remotas Ponga en marcha un proceso repetible, de propiedad o control técnico para requerir MFA para acceso remoto a redes, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Entradas de subvención/revocación, cobertura del MFA, inventario del sistema de autenticación, funciones, derechos y exámenes de acceso tención 6.5 Silencioso Consultar MFA para el acceso administrativo Poner en marcha un proceso repetible, de propiedad o control técnico para exigir el MFA de Acceso Administrativo, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Entradas de subvención/revocación, cobertura del MFA, inventario del sistema de autenticación, funciones, derechos y exámenes de acceso Silencio 6.6 Silencio Establecer y mantener un inventario de sistemas de autenticación y autorización Silencio Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener un inventario de sistemas de autenticación y autorización, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Entradas de subvención/revocación, cobertura del MFA, inventario del sistema de autenticación, funciones, derechos y exámenes de acceso Silencio 6.7 Silencio Centralizar control de acceso Ponga en marcha un proceso repetible, de propiedad o control técnico para centralizar el control de acceso, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Entradas de subvención/revocación, cobertura del MFA, inventario del sistema de autenticación, funciones, derechos y exámenes de acceso Silencio 6.8 Silencio Definir y mantener el control de acceso basado en roles Ponga en marcha un proceso repetible, de propiedad o control técnico para definir y mantener el control de acceso basado en roles, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Entradas de subvención/revocación, cobertura del MFA, inventario del sistema de autenticación, funciones, derechos y exámenes de acceso

— Silencio 7.1 Silencio Establecer y mantener un proceso de gestión de vulnerabilidades TENIDO Poner en marcha un proceso repetible, de propiedad o control técnico para establecer y mantener un proceso de gestión de vulnerabilidades, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. procesos, alimentaciones, cobertura de activos, escaneos autenticados, resultados de parches, excepciones, boletos de remediación y

rescans TEN 7.2 TENIDO Establecer y mantener un proceso de rehabilitación TENIDO Poner en marcha un proceso de repetición, propiedad o control técnico para establecer y mantener un proceso de rehabilitación, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. procesos, alimentaciones, cobertura de activos, escaneos autenticados, resultados de parches, excepciones, boletos de remediación y rescans Silencio 7.3 Silencio Perform Automatizado Sistema Operativo Manejo de parche Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar Automated Operating System Patch Management, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. procesos, alimentaciones, cobertura de activos, escaneos autenticados, resultados de parches, excepciones, boletos de remediación y rescans Silencio 7.4 ► Perform Automated Application Patch Management Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar Automated Application Patch Management, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. procesos, alimentaciones, cobertura de activos, escaneos autenticados, resultados de parches, excepciones, boletos de remediación y rescans Silencio 7.5 Silencio Perform Automated Vulnerability Scans of Internal Enterprise Assets tención Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar escáneres de vulnerabilidad automatizados de activos de empresa interna, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. procesos, alimentaciones, cobertura de activos, escaneos autenticados, resultados de parches, excepciones, boletos de remediación y rescans TEN 7.6 ANTE Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets TEN Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar escáneres de vulnerabilidad automatizados de activos de empresas externamente expuestas, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. procesos, alimentaciones, cobertura de activos, escaneos autenticados, resultados de parches, excepciones, boletos de remediación y rescans Silencio 7.7 Silencio Remediate Detected Vulnerabilities – Poner en marcha un proceso repetible, de propiedad o control técnico para remediar Vulnerabilidades Detectadas, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. procesos, alimentaciones, cobertura de activos, escaneos autenticados, resultados de parches, excepciones, boletos de remediación y rescans

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

13. Control 8 — Audit Log Management

Las 12 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** La vida

tención 8.1 Silencio Establecer y mantener un proceso de gestión de los registros de auditoría – Poner en marcha un proceso repetible, de propiedad o control técnico para establecer y mantener un proceso de gestión de los registros de auditoría, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo, registros detallados, plataforma central, revisiones y retención Silencio 8.2 Silencio Recopilar los registros de auditoría Ponga en marcha un proceso repetible, de propiedad o control técnico para recopilar los registros de auditoría, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo, registros detallados, plataforma central, revisiones y retención Silencio 8.3 Silencio Asegurar Adequate Audit Log Storage Ponga en marcha un proceso repetible, de propiedad o control técnico para garantizar el almacenamiento adecuado de registros de auditoría, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo, registros detallados, plataforma central, revisiones y retención Silencio 8.4 – Normalizar la sincronización del tiempo – Poner en marcha un proceso repetible, de propiedad o control técnico para estandarizar la sincronización del tiempo, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo,

registros detallados, plataforma central, revisiones y retención Silencio 8.5 Silencio Recopilar Registros de Auditoría detallados Silencio Ponga en marcha un proceso repetible, de propiedad o control técnico para recoger los registros de auditoría detallados, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo, registros detallados, plataforma central, revisiones y retención Silencio 8.6 Silencio Collect DNS Query Audit Logs Ponga en marcha un proceso repetible, de propiedad o control técnico para recoger los registros de auditoría de consultas DNS, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo, registros detallados, plataforma central, revisiones y retención Silencio 8.7 Silencio Collect URL Request Audit Logs – Ponga en marcha un proceso repetible, de propiedad o control técnico para recopilar URL Solicitar registros de auditoría, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo, registros detallados, plataforma central, revisiones y retención Silencio 8.8 Silencio Coleccion Command-Line Audit Logs Ponga en marcha un proceso repetible, de propiedad o control técnico para recoger los registros de auditoría de Command-Line, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo, registros detallados, plataforma central, revisiones y retención Silencio 8.9 Silencio Centralizar los registros de auditoría Poner en marcha un proceso repetible, de propiedad o control técnico para centralizar los registros de auditoría, a continuación, verificar la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo, registros detallados, plataforma central, revisiones y retención Silencio 8.10 Silencio Retener los registros de auditoría Poner en marcha un proceso repetible, de propiedad o control técnico para retener los registros de auditoría, verificar la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo, registros detallados, plataforma central, revisiones y retención Silencio 8.11 Silencio Realizar Auditorías Reseñas Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar revisiones de los registros de auditoría, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo, registros detallados, plataforma central, revisiones y retención Silencio 8.12 Silencio Collect Service Provider Logs Ponga en marcha un proceso repetible, de propiedad o control técnico para recoger registros de proveedores de servicios, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo, registros detallados, plataforma central, revisiones y retención

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

14. Control 9 - Protección de correo electrónico y navegador web

Las 7 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la implementación y medición de salvaguardias para las protecciones de correo electrónico y navegador web. Silencio

Respuesta

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** La vida

[illegible]

TEN 9.1 TENCIÓN Asegurar el uso de sólo navegadores completos y clientes de correo electrónico TENIDO Poner en marcha un proceso repetible, propiedad o control técnico para garantizar el uso de sólo navegadores completos y clientes de correo electrónico, a continuación, verificar la cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN navegador e inventarios de correo electrónico, estado de soporte, filtrado DNS/URL, política de extensión, DMARC y controles de apego TEN 9.2 TENIDO Utilizar DNS Filtrar Servicios ANTEPóngase en marcha un proceso repetible, de propiedad o

control técnico para utilizar DNS Filtering Services, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN navegador e inventarios de correo electrónico, estado de soporte, filtrado DNS/URL, política de extensión, DMARC y controles de apego Silencio 9.3 Silencio Mantener y Forzar Filtros de URL basados en la red Ponga en marcha un proceso repetible, de propiedad o control técnico para mantener y ejecutar filtros de URL basados en red, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN navegador e inventarios de correo electrónico, estado de soporte, filtrado DNS/URL, política de extensión, DMARC y controles de apego Silencio 9.4 Silencio Restringir Extensiones innecesarias o no autorizadas de navegador y correo electrónico de clientes Silencio Ponga un proceso repetible, propiedad o control técnico en su lugar para restringir Extensiones innecesarias o no autorizadas de navegador y cliente de correo electrónico, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN navegador e inventarios de correo electrónico, estado de soporte, filtrado DNS/URL, política de extensión, DMARC y controles de apego TEN 9.5 TENIDO Implement DMARC ANTEPonga un proceso repetible, de propiedad o control técnico en marcha para implementar DMARC, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN navegador e inventarios de correo electrónico, estado de soporte, filtrado DNS/URL, política de extensión, DMARC y controles de apego TEN 9.6 TENIDO Bloquear Tipos de archivo innecesarios Ponga en marcha un proceso repetible, de propiedad o control técnico para bloquear los tipos de archivos innecesarios, a continuación, verifique la cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN navegador e inventarios de correo electrónico, estado de soporte, filtrado DNS/URL, política de extensión, DMARC y controles de apego Silencio 9.7 Silencio Despliegue y Mantenga el Servidor de Email Anti-Malware Protecciones Ponga en marcha un proceso repetible, de propiedad o control técnico para implementar y Mantener Protecciones Anti-Malware del Servidor de Email, a continuación, verifique la cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN navegador e inventarios de correo electrónico, estado de soporte, filtrado DNS/URL, política de extensión, DMARC y controles de apego

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

15. Control 10 — Malware Defenses

Las 7 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la implementación y medición de salvaguardias para defensas de malware. Silencio Silencio...

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** Silencio

----- Silencio 10.1 Silencio
Deploy y Mantener el Software Anti-Malware Ponga en marcha un proceso repetible, de propiedad o control técnico para desplegar y mantener el software antimalware, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura de endpoint, configuración anti-malware, actualizaciones, controles de medios extraíbles, alertas de comportamiento y tickets de respuesta Silencio 10.2 Silencio Configure Actualizaciones automáticas de firmas antimalware Ponga en marcha un proceso repetible, de propiedad o control técnico para configurar Actualizaciones automáticas de firmas antimalware, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura de endpoint, configuración anti-malware, actualizaciones, controles de medios extraíbles, alertas de comportamiento y tickets de respuesta TEN 10.3 TENIDO Autorun deshabilitado y Autoplay para medios extraíbles TENIENDO Poner en marcha un proceso repetible, propiedad o control técnico para desactivar Autorun y Autoplay para medios extraíbles, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura de endpoint, configuración anti-malware, actualizaciones, controles de medios extraíbles, alertas de comportamiento y tickets de respuesta Silencio 10.4 Silencio Configure Automatic Anti-Malware Scanning of Removable Media Ponga en marcha un proceso repetible, de propiedad o control técnico para configurar el escaneado automático antimalware de medios extraíbles, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura de endpoint, configuración anti-malware, actualizaciones, controles de medios extraíbles, alertas de comportamiento y tickets de respuesta Silencio 10.5 Silencio

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

Las 5 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** Silencio

[illegible]

TEN 11.1 TENIDO Establecer y mantener un proceso de recuperación de datos TENIDO Poner en marcha un proceso repetible, de propiedad o control técnico para establecer y mantener un proceso de recuperación de datos, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Plan de recuperación, cobertura de copia de seguridad, copias protegidas y aisladas, pruebas de restauración, resultados, brechas y retests TEN Silencio 11.2 Silencio Perform Automated Backups Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar copias de seguridad automatizadas, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Plan de recuperación, cobertura de copia de seguridad, copias protegidas y aisladas, pruebas de restauración, resultados, brechas y retests TEN Silencio 11.3 Silencio para proteger los datos de recuperación Ponga en marcha un proceso repetible, de propiedad o control técnico para proteger los datos de recuperación, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Plan de recuperación, cobertura de copia de seguridad, copias protegidas y aisladas, pruebas de restauración, resultados, brechas y retests TEN TEN 11.4 TENIDO Establecer y mantener una instalación aislada de datos de recuperación TENIDO Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener una instalación aislada de datos de recuperación, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Plan de recuperación, cobertura de copia de seguridad, copias protegidas y aisladas, pruebas de restauración, resultados, brechas y retests TEN TEN 11.5 TENIDO Recuperar Datos de Prueba TENIDO Poner en marcha un proceso repetible, propiedad o control técnico para probar la recuperación de datos, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Plan de recuperación, cobertura de copia de seguridad, copias protegidas y aisladas, pruebas de restauración, resultados, brechas y retests TEN

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

Control 12 - Gestión de la infraestructura de red

Las 8 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la gestión de la infraestructura de red. Silencio Respuesta

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** Silencio

—- Enviado Silencio 12.1 Silencio Garantizar que la infraestructura de red esté actualizada Ponga en marcha un proceso repetible, de propiedad o control técnico para asegurar que la infraestructura de red esté actualizada, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración Silencio 12.2 Silencio Establecer y mantener una arquitectura de red segura – Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener una arquitectura de red segura, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración Silencio 12.3 – Gestión segura de la infraestructura de red Ponga en marcha un proceso repetible, de propiedad o control técnico para gestionar de forma segura la infraestructura de red, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración TEN 12.4 TENIDO Establecer y mantener los diagramas de arquitectura TENIDO Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener los diagramas de arquitectura, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración Silencio 12.5 Silencio Centralizar Autenticación, Autorización y Auditoría de la Red Silencio Poner en marcha un proceso repetible, de propiedad o control técnico para centralizar la autenticación, Autorización y Auditoría de la Red, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración TEN 12.6 TENIDO Utilizar protocolos de gestión y comunicación de redes seguras Ponga en marcha un proceso repetible, de propiedad o control técnico para utilizar protocolos de gestión y comunicación de redes seguras, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración Silencio 12.7 Silencio Garantizar dispositivos remotos Utilice una VPN y Enterprise AAA Silencio Ponga en marcha un proceso repetible, de propiedad o control técnico para asegurar dispositivos remotos Use una VPN y Enterprise AAA, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración Silencio 12.8 Silencio Mantener los recursos de computación dedicados para el trabajo administrativo Poner en marcha un proceso repetible, de propiedad o control técnico para mantener los Recursos de Computación Dedicada

para el Trabajo Administrativo, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

18. Control 13 — Network Monitoring and Defense

Todas las 11 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

■img src="media/image8.png" estilo="width:6.15in;height:3.20094in" alt="Contexto centralizado, detección sintonizada, investigación humana y respuesta crean defensa útil".

Figure 8. Monitoring-to-response workflow

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la implementación y medición de salvaguardias para el monitoreo y defensa de redes. Silencio Silencio...

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** Silencio

- Silencio 13.1 Silencio Centralizar Seguridad Evento Alertar Silencio Ponga en marcha un proceso repetible, de propiedad o control técnico para centralizar la alerta de eventos de seguridad, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de prevención y alerta de afinación Silencio 13.2 Silencio Despliegue una Solución de Detección de Intrusión Basada en Host Ponga en marcha un proceso repetible, de propiedad o control técnico para desplegar una Solución de Detección de Intrusión Basada en Host, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de prevención y alerta de afinación Silencio 13.3 Silencio Despliegue una Solución de detección de intrusiones de red Ponga en marcha un proceso repetible, de propiedad o control técnico para implementar una Solución de Detección de Intrusión de Red, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de

prevención y alerta de afinación Silencio 13.4 Silencio Realizar filtración de tráfico entre Segmentos de red Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar el Filtro de tráfico entre segmentos de red, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de prevención y alerta de afinación Silencio 13.5 Silencio Manage Access Control for Remote Assets Ponga en marcha un proceso repetible, de propiedad o control técnico para gestionar el control de acceso para activos remotos, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de prevención y alerta de afinación Silencio 13.6 ► Collect Network Traffic Flow Logs Ponga en marcha un proceso repetible, de propiedad o control técnico para recoger los Logs de flujo de tráfico de red, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de prevención y alerta de afinación Silencio 13.7 Silencio Despliegue una solución de prevención de la intrusión basada en el hogar Ponga en marcha un proceso repetible, de propiedad o control técnico para desplegar una solución de prevención de la intrusión basada en el host, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de prevención y alerta de afinación Silencio 13.8 Silencio Despliegue una Solución de Prevención de Intrusiones de Redes Silencio Ponga en marcha un proceso repetible, de propiedad o control técnico para implementar una Solución de Prevención de Intrusiones de Red, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de prevención y alerta de afinación Silencio 13.9 Ponga en marcha un proceso repetible, de propiedad o control técnico para desplegar Port-Level Access Control, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de prevención y alerta de afinación Silencio 13.10 Silencio Perform Application Layer Filtering Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar el Filtro de capa de aplicaciones, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de prevención y alerta de afinación Silencio 13.11 Silencio Seguridad de la Tune Alerta de eventos Ubica un proceso repetible, de propiedad o control técnico en su lugar para sintonizar Security Event Alerting Thresholds, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de prevención y alerta de afinación

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

19. Control 14 - Capacitación en conciencia de seguridad y habilidades

Las 9 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la sensibilización en materia de seguridad y la capacitación en aptitudes.
Silencio Silencio...

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** Silencio

----- TEN 14.1 TENIDO Establecer y mantener un programa de conciencia de seguridad TENIDO Poner en marcha un proceso de repetición, propiedad o control técnico para establecer y mantener un programa de conciencia de seguridad, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. programa tención, población laboral, programa de trabajo, finalización, simulaciones, evaluación, excepciones y seguimiento Silencio 14.2 Silencio Entrenar a los miembros de la fuerza de trabajo para reconocer ataques de ingeniería social – Poner en marcha un proceso repetible, propiedad o control técnico para capacitar a los miembros de la fuerza de trabajo para reconocer ataques de ingeniería social, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. programa tención, población laboral, programa de trabajo, finalización, simulaciones, evaluación, excepciones y seguimiento TEN 14.3 TENIDO Entrenar a los miembros de la fuerza de trabajo sobre la autenticación Buenas Prácticas TENIDO Poner en marcha un proceso repetible, de propiedad o control técnico para capacitar a los miembros de la fuerza de trabajo sobre las mejores prácticas de autenticación, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. programa tención, población laboral, programa de trabajo, finalización, simulaciones, evaluación, excepciones y seguimiento Silencio 14.4 Silencio Train Workforce on Data Handling Best Practices TEN Poner en marcha un proceso repetible, propiedad o control técnico para capacitar a Workforce en Data Handling Best Practices, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. programa tención, población laboral, programa de trabajo, finalización, simulaciones, evaluación, excepciones y seguimiento Silencio 14.5 Silencio Entrenar a los miembros de la fuerza de trabajo sobre las causas de la exposición de datos no intencionales ! Ponga en marcha un proceso repetible, de propiedad o control técnico para capacitar a los miembros de la fuerza de trabajo sobre las causas de la exposición de datos no

intencionales, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. programa tención, población laboral, programa de trabajo, finalización, simulaciones, evaluación, excepciones y seguimiento Silencio 14.6 Silencio Entrenar a los miembros de la fuerza de trabajo para reconocer y denunciar incidentes de seguridad – Poner en marcha un proceso repetible, de propiedad o control técnico para capacitar a los miembros de la fuerza de trabajo en reconocer y denunciar incidentes de seguridad, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. programa tención, población laboral, programa de trabajo, finalización, simulaciones, evaluación, excepciones y seguimiento Silencio 14.7 Silencio Train Workforce para identificar e informar Actualizaciones de Seguridad Desaparecidas Silencio Ponga en marcha un proceso repetible, de propiedad o control técnico para capacitar a Workforce para identificar y reportar actualizaciones de seguridad desaparecidas, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. programa tención, población laboral, programa de trabajo, finalización, simulaciones, evaluación, excepciones y seguimiento TEN 14.8 TENIDO Capacitación Fuerza de Trabajo sobre Riesgos de Redes Inseguras TENIDO Poner en marcha un proceso repetible, de propiedad o control técnico para capacitar a Workforce en Riesgos de Redes Inseguras, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. programa tención, población laboral, programa de trabajo, finalización, simulaciones, evaluación, excepciones y seguimiento TEN 14.9 TENIDO Conduct Role-Specific Security Awareness and Skills Training TENGA un proceso repetible, de propiedad o control técnico en su lugar para llevar a cabo el entrenamiento de conciencia y habilidades de seguridad del papel-espejo, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. programa tención, población laboral, programa de trabajo, finalización, simulaciones, evaluación, excepciones y seguimiento

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

20. Control 15 — Service Provider Management

Las 7 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la gestión de proveedores de servicios. Silencio Silencio...

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** Silencio

-----TEN 15.1 TENIDO Establecer y mantener un inventario de proveedores de servicios TENIDO Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener un inventario de proveedores de servicios, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario, clasificaciones, políticas, contratos, evaluaciones, vigilancia, incidentes y pruebas de descomposición Silencio 15.2 Silencio Establecer y mantener una Política de Gestión de Proveedores de Servicios – Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener una Política de Gestión de Proveedores de Servicios, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario, clasificaciones, políticas, contratos, evaluaciones, vigilancia, incidentes y pruebas de descomposición Silencio 15.3 Ponga en marcha un proceso repetible, de propiedad o control técnico para clasificar a los proveedores de servicios, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario, clasificaciones, políticas, contratos, evaluaciones, vigilancia, incidentes y pruebas de descomposición Silencio 15.4 Silencio Garantizar Contratos de Proveedor de Servicios Incluir Requisitos de Seguridad Silencio Poner en marcha un proceso de repetibilidad, propiedad o control técnico para garantizar contratos de Proveedor de Servicios Incluir Requisitos de Seguridad, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario, clasificaciones, políticas, contratos, evaluaciones, vigilancia, incidentes y pruebas de descomposición Silencio 15.5 Silenciosos Proveedores de Servicios Silencio Ponga en marcha un proceso repetible, de propiedad o control técnico para evaluar a los Proveedores de Servicios, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario, clasificaciones, políticas, contratos, evaluaciones, vigilancia, incidentes y pruebas de descomposición Silencio 15.6 Poner en marcha un proceso repetible, de propiedad o control técnico para supervisar a los proveedores de servicios, verificar la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario, clasificaciones, políticas, contratos, evaluaciones, vigilancia, incidentes y pruebas de descomposición Silencio 15.7 Silencio Proveedores de Servicio de Decomiso Seguro Ponga en marcha un proceso repetible, de propiedad o control técnico para desactivar de forma segura los proveedores de servicios, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario, clasificaciones, políticas, contratos, evaluaciones, vigilancia, incidentes y pruebas de descomposición

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

Control 16 - Seguridad del Software de Aplicación

Todas las 14 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la seguridad de los programas de aplicación. Silencio Silencio...

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** Silencio

----- Silencio 16.1 Silencio
Establecer y mantener un proceso de desarrollo de aplicaciones seguras – Poner en marcha un proceso de repetición, propiedad o control técnico para establecer y mantener un proceso de desarrollo de aplicaciones seguras, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza TEN Silencio 16.2 Silencio Establecer y mantener un proceso para aceptar y abordar Vulnerabilidades de Software Silencio Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener un proceso para aceptar y abordar vulnerabilidades de software, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza TEN Silencio 16.3 Silencio Realizar análisis de causa raíz sobre vulnerabilidades de seguridad Silencio Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar análisis de causa raíz sobre vulnerabilidades de seguridad, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza TEN Silencio 16.4 Silencio Establecer y administrar un inventario de componentes de software de terceros |Ponga un proceso repetible, propiedad o control técnico en su lugar para establecer y administrar un inventario de componentes de software de terceros, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza TEN Silencio 16.5 – Utilizar componentes de software de terceros actualizados y confiados Ponga en marcha un proceso repetible, de propiedad o control técnico para utilizar componentes de software de terceros actualizados y confiados, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza TEN Silencio 16.6 Silencio Establecer un sistema de puntuación de la gravedad y proceso para aplicaciones Vulnerabilidades TENIDO Poner en marcha un proceso repetible, de propiedad o control

técnico para establecer un sistema de puntuación de la gravedad y el proceso para aplicaciones Vulnerabilidades, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza TEN TEN 16.7 TENIDO Use Plantillas de endurecimiento estándar para infraestructura de aplicaciones TENIDO Ponga en marcha un proceso repetible, de propiedad o control técnico para utilizar plantillas de endurecimiento estándar para infraestructura de aplicaciones, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza TEN Silencio 16.8 Silencio Sistemas de Producción Separada y No Producción Poner en marcha un proceso repetible, de propiedad o control técnico para separar los sistemas de producción y no producción, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza TEN Silencio 16.9 Silencio Desarrolladores de Tren en Seguridad de Aplicaciones y Codificación Asegurada Ponga en marcha un proceso repetible, propiedad o control técnico para capacitar a Desarrolladores en Seguridad de Aplicaciones y Codificación Asegurada, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza TEN Silencio 16.10 Silencio Aplicar Principios de Diseño Seguro en Arquitecturas de Aplicaciones Silencio Ponga en marcha un proceso repetible, de propiedad o control técnico para aplicar Principios de Diseño Seguro en Arquitecturas de Aplicaciones, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza TEN TEN 16.11 TENIDO Utilizar Módulos o Servicios Vetted para componentes de seguridad de aplicaciones TEN Poner en marcha un proceso repetible, de propiedad o control técnico para utilizar módulos o servicios para componentes de seguridad de aplicaciones, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza TEN Silencio 16.12 Silencio Implementar Controles de Seguridad del Code-Level Ponga en marcha un proceso repetible, de propiedad o control técnico para implementar los controles de seguridad de Code-Level, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza TEN Silencio 16.13 Silencio Conducir Aplicación Pruebas de Penetración Ponga en marcha un proceso repetible, de propiedad o control técnico para llevar a cabo pruebas de penetración de aplicaciones, a continuación, verifique cobertura y excepciones. tención

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

Las 9 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Gráfico 9. Preparación para respuesta a incidentes

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** La vida

[illegible]

Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Silenciosos líderes, contactos, informes, plan, roles, comunicaciones, ejercicios, revisiones y umbrales Silencio 17.2 Silencio Mantener Información de Contacto para Reportar Incidentes de Seguridad Silencio Poner en marcha un proceso repetible, propiedad o control técnico para mantener la Información de Contacto para Reportar Incidentes de Seguridad, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Silenciosos líderes, contactos, informes, plan, roles, comunicaciones, ejercicios, revisiones y umbrales Silencio 17.3 Silencio Mantener un Proceso Empresarial para la Presentación de Informes Incidentes Silencio Poner en marcha un proceso repetible, propiedad o control técnico para mantener un Proceso Empresarial para la Presentación de Informes Incidentes, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Silenciosos líderes, contactos, informes, plan, roles, comunicaciones, ejercicios, revisiones y umbrales TEN 17.4 TENIDO Establecer y mantener un proceso de respuesta de incidentes TENIDO Poner en marcha un proceso de repetición, propiedad o control técnico para establecer y mantener un proceso de respuesta de incidentes, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Silenciosos líderes, contactos, informes, plan, roles, comunicaciones, ejercicios, revisiones y umbrales TEN 17.5 TENIDO Asignar Funciones y responsabilidades clave ANTEPonga un proceso repetible, de propiedad o control técnico en su lugar para asignar funciones y responsabilidades clave, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Silenciosos líderes, contactos, informes, plan, roles, comunicaciones, ejercicios, revisiones y umbrales TEN 17.6 ANTERIENTE Definir los mecanismos de comunicación durante la respuesta de incidentes Poner en marcha un proceso repetible, de propiedad o control técnico para definir mecanismos de comunicación durante la respuesta de incidentes, a continuación, verificar la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Silenciosos líderes, contactos, informes, plan, roles, comunicaciones, ejercicios, revisiones y umbrales Silencio 17.7 Silencio Conduct Routine Incident Response Ejercicios Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar ejercicios de respuesta de incidentes de rutina, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Silenciosos líderes, contactos, informes, plan, roles, comunicaciones, ejercicios, revisiones y umbrales Silencio 17.8 Silencio Conducir Reseñas posteriores a incidentes Poner en marcha un proceso repetible, de propiedad o control técnico para llevar a cabo revisiones post-incidente, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Silenciosos líderes, contactos, informes, plan, roles, comunicaciones, ejercicios, revisiones y umbrales Silencio 17.9 Silencio Establecer y Mantener Umbral de Incidentes de Seguridad Silencio Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener Umbrales de Incidentes de Seguridad, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia,

cobertura, excepciones, corrección y retest. Silenciosos líderes, contactos, informes, plan, roles, comunicaciones, ejercicios, revisiones y umbrales

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

23. Control 18 — Penetration Testing

Las 5 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

Silencio ** Objetivo de control:** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para las pruebas de penetración. Silencio Silencio...

Silencio **** Silencio ** Salvaguardia** Silencio **Plain meaning** Silencio ** Enfoque de la verificación** Silencio

----- Silencio 18.1 Silencio Establecer y mantener un Programa de Pruebas de Penetración Silencio Poner en marcha un proceso repetible, de propiedad o control técnico para establecer y mantener un Programa de Pruebas de Penetración, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN aprobó reglas de compromiso, alcance, testadores cualificados, informes, remediación, pruebas de retest y validación Silencio 18.2 Silencio Realizar exámenes periódicos de penetración externa Poner en marcha un proceso repetible, de propiedad o control técnico para realizar exámenes periódicos de penetración externa, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN aprobó reglas de compromiso, alcance, testadores cualificados, informes, remediación, pruebas de retest y validación Silencio 18.3 – Búsquedas de Penetración Remediar Ponga un proceso repetible, de propiedad o control técnico en su lugar para remediar Penetration Test Findings, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN aprobó reglas de compromiso, alcance, testadores cualificados, informes, remediación, pruebas de retest y validación Silencio 18.4 Poner en marcha un proceso repetible, de propiedad o control técnico para validar las medidas de seguridad, verificar la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN aprobó reglas de compromiso, alcance, testadores cualificados, informes, remediación, pruebas de retest y validación Silencio 18.5 Silencio Realizar exámenes periódicos de penetración interna Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar exámenes periódicos de penetración interna, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN aprobó

reglas de compromiso, alcance, testadores cualificados, informes, remediación, pruebas de retest y validación

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

24. Herramientas de código abierto

- Enlaces oficiales, inicios rápidos seguros, pruebas y limitaciones.*

Silencio **Herramienta** Silencio** Silencio----- La vida
----- TEN CIS Controls Navigator TEN Seleccionar IGs y explorar asignaciones
oficiales TEN TODO TENIDO Evaluación de Controles de CIS Especificación – Orientación
oficial de medición Silencio CIS-CAT Lite – Selected CIS Evaluación de parámetros latitud 4
TENIDO CISO Asistente TENIDO Controles, riesgos, pruebas y hallazgos tención Wazuh –
Endpoint monitoring, SIEM, FIM, y alertas TEN Osquery TENRI Asset, software, cuenta y
consultas de configuración TEN OpenSCAP TENIDO Evaluación de la configuración segura de
Linux TEN 4, 7 TEN Silencio Lynis para la seguridad de Linux auditando Silencio 4, 7 Silencio
Silencio Nmap Silencio Autorizado activo y descubrimiento de servicios Silencio 1, 12 Silencio
Greenbone Community Edition Silencio Vulnerability assessment Silencio 7 tención Trivy
Silencioso Repositorios, imágenes, dependencias, secretos, y IaC Silencioso 2, 4, 7, 16 Silencio
Silencio OWASP ZAP Silencio Pruebas autorizadas de seguridad web Silencio Suricata Silencio
Red detección de intrusiones y visibilidad de tráfico Silencio 8, 13, 17 Silencio TENER Keycloak
TENIDO Identidad, roles, MFA, sesiones y eventos – DefectoDojo tóxico Encontrar la ingesta, la
deduplicación, la remediación y la retesta Silencio 7, 16, 18 Silencio Velociraptor Silencio
Visibilidad de endpoint y respuesta a los incidentes

- Limitación crítica* Una herramienta puede apoyar una o más Salvaguardias, pero no puede elegir el IG de la organización, definir la tolerancia al riesgo, garantizar la cobertura completa, reemplazar el procedimiento y la revisión humana, autorizar pruebas de penetración, o probar el cumplimiento de otro marco por sí mismo. Silencio Silencio.

24.1 CIS Controls Navigator

Propósito: Seleccione IGs y explore mapas oficiales. Proyecto oficial: [ejecutado] CIS Controles Navigator efectuado/u fiel](<https://www.cisecurity.org/controls/cis-controls-navigator>)

Inicio rápido seguro: Elija v8.1, seleccione un grupo de implementación y mapeo, revise salvaguardias, luego exporte la selección autorizada.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.2 CIS Controls Assessment Specification

Objetivo: Orientación oficial de medición. Proyecto oficial: [Seguido] [Según datos](#)

Inicio rápido seguro: Abra una Salvaguardia, identifique los insumos y las suposiciones, siga las operaciones, calcule las medidas y revise el procedimiento de documentos.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.3 CIS-CAT Lite

Propósito: CIS seleccionado Evaluación de parámetros. Proyecto oficial: [Seguido] (<https://learn.cisecurity.org/cis-cat-lite>)

Inicio rápido seguro: Ejecutar sólo en sistemas autorizados, elegir un punto de referencia y perfil disponibles, preservar el informe, validar las conclusiones, corregir y reevaluar.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.4 CISO Assistant

Propósito: Controles, riesgos, pruebas y hallazgos. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Crear un proyecto de alcance, cargar un marco aplicable, asignar propietarios, adjuntar evidencia, resultados de seguimiento y permisos de revisión.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.5 Wazuh

Propósito: Monitoreo de punto final, SIEM, FIM y alertas. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Inscribir un punto final de laboratorio, desencadenar un evento seguro, confirmar la recogida y alerta, investigar, y retener la cobertura y la evidencia de respuesta.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.6 osquery

Propósito: Consultas de activos, software, cuenta y configuración. Proyecto oficial: (<https://www.osquery.io/>)

Comienzo rápido seguro: Ejecute consultas sólo de lectura en un laboratorio, programe consultas aprobadas, compare resultados a inventarios, y plataforma de documentos y límites de cobertura.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.7 OpenSCAP

Objetivo: Evaluación de la configuración segura de Linux. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Elija un perfil apropiado, escanear un sistema de laboratorio, validar resultados, excepciones de documentos, remediar y cambiar.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.8 Lynis

Propósito: Auditoría de seguridad de Linux. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: auditar un host de laboratorio, revisar los hallazgos contra el alcance y las normas, asignar acciones, corregir elementos seleccionados y repetir.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.9 Nmap

Propósito: Activo autorizado y descubrimiento de servicios. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Usar un escaneo limitado en rangos escritos, comparar con inventario, investigar servicios desconocidos, y retener el alcance y la evidencia de comando.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.10 Greenbone Community Edition

Objetivo: Evaluación de la vulnerabilidad. Proyecto oficial: [ejecutado]Greenbone Community Edition (10)(<https://greenbone.github.io/docs/latest/>)

Inicio rápido seguro: Actualizar los alimentos, utilizar los objetivos autorizados y las credenciales, validar la cobertura de activos, revisar las conclusiones, remediar y cambiar.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.11 Trivy

Propósito: Repositorios, imágenes, dependencias, secretos e IaC. Proyecto oficial: [ejecutado]Trivy seleccionado/u fiel](<https://trivy.dev/>)

Inicio rápido seguro: Escanear un repositorio de prueba o imagen, validar hallazgos, documentar excepciones justificadas, fijar y rescán en el oleoducto.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.12 OWASP ZAP

Propósito: Pruebas de seguridad web autorizadas. Proyecto oficial: [Seguido] (<https://www.zaproxy.org/>)

Comenzar rápido seguro: Proxy una aplicación de entrenamiento, arrastrar pasivamente, utilizar el escaneo activo sólo con aprobación, validar hallazgos, correcto y retest.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.13 Suricata

Propósito: detección de intrusión en red y visibilidad del tráfico. Proyecto oficial: [Seguido] (<https://suricata.io/>)

Inicio rápido seguro: Use un sensor de laboratorio, confirme la interfaz y las reglas, genere tráfico de prueba aprobado, valide alertas, sintonice cuidadosamente, y preserve la historia del cambio.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.14 Keycloak

Propósito: Identidad, roles, MFA, sesiones y eventos. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Crear un reino de laboratorio, roles y MFA, probar casos de compás, revisar eventos y configuración de documentos y resultados.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.15 DefectoDojo

Propósito: Encontrar ingesta, deduplicación, remediación y retest. Proyecto oficial: [Seguido](#)

Comienzo rápido seguro: Importar resultados seguros, validar la deduplicación, asignar propietarios y fechas, adjuntar prueba, y cerrar sólo después de la prueba verificada.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

24.16 Velociraptor

Finalidad: visibilidad y respuesta a incidentes. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Despliegue sólo en un laboratorio autorizado aislado, recoja un artefacto estrecho, alcance de documentos y acceso, investigue los resultados y retire los datos del laboratorio con seguridad.

Pruebas: alcance aprobado, versión, configuración, cobertura, datos fuente, resultados, examen humano, excepción, remediación y retest. Proteger el acceso administrativo y los datos recogidos.

25. Manual de Controles CIS de Manager

Las preguntas, el tablero, la propiedad y los administradores de decisiones deben controlar.

1. ¿El IG elegido sigue siendo apropiado para datos sensibles, servicios críticos, exposición a amenazas, obligaciones, escala y habilidades?
2. ¿Están las poblaciones centrales completas, actuales, de propiedad y reconciliadas con el descubrimiento independiente?
3. ¿Qué Salvaguardias IG1 tienen cobertura incompleta, revisión atrasada, datos de entrada no fiables o excepciones de repetición?
4. ¿Se han intensificado los accesos administrativos, los sistemas expuestos externamente, los programas informáticos no respaldados, las vulnerabilidades críticas y los fallos de recuperación?
5. ¿Las alertas resultan en investigación y respuesta, o sólo en el volumen de panel?
6. ¿Se entienden las responsabilidades de los proveedores de servicios, las pruebas, las obligaciones de incidentes, los subcontratistas y los planes de salida?
7. ¿Se autorizan pruebas de penetración y ejercicios de forma segura, con un alcance adecuado, realizados independientemente cuando sea necesario y seguidos a través de la prueba?
8. ¿Qué financiación, personal, tiempo de ingeniería o decisión empresarial está bloqueando la corrección?

Area Silencio ** Cuestión del personal Silencio**————— **Silencio IG y alcance Silencio** ¿Se documentan las prioridades, adiciones, exclusiones y obligaciones? Verde /

Amarillo / Rojo – Inventories Silencio ¿Están completos los activos, software, datos, cuentas, proveedores, aplicaciones y registros? Verde / Amarillo / Rojo TEN Protection TEN ¿Operan la configuración, el acceso, el parche, el correo electrónico, el malware y los controles de datos? Verde / Amarillo / Rojo Silencio Detección Silencio ¿Se ha completado la cobertura de registro y red y se han revisado las alertas? Verde / Amarillo / Rojo – Recuperación Silencio ¿Están protegidos copias de seguridad y restauraciones probadas contra las necesidades de negocio? Verde / Amarillo / Rojo Silencio Respuesta Silencio ¿Son los roles, contactos, umbrales, ejercicios y revisiones actuales? Verde / Amarillo / Rojo TENED ¿Se corrigieron las poblaciones confiables y de excepción? Verde / Amarillo / Rojo ¿Son compatibles las pruebas, limitaciones, hallazgos y pruebas? Verde / Amarillo / Rojo

26. Junior Analyst Career Guide

Una ruta práctica en controles, vulnerabilidad, seguridad, GRC y operaciones de seguridad funcionan.

■img src="media/image10.png" style="width:6.15in;height:2.9948lin" alt="Aprende el marco, mapa Salvaguardias, mide evidencia, reporte lagunas, y construya un portafolio honesto".

Gráfico 10 Junior CIS Controles vía analista

Controles de Seguridad Junior Analista

GRC Analista

Analista de Gestión de Vulnerabilidad

Análisis de la seguridad

Análisis de las operaciones de seguridad

Analista de Cumplimiento de TI

Third-Party Risk Analyst

Cybersecurity Program Analyst

26.1 Típico trabajo junior

- Mantener inventarios de activos, software, datos, cuentas, sistemas de red, proveedores, aplicaciones, hallazgos y pruebas.
- Reunir pruebas sin cambiar los registros de fuentes y validar la integridad de la población.
- Mapa Salvaguardias a propietarios, sistemas, procedimientos, configuración, evidencia, métricas, excepciones y acciones.
- Ejecute las herramientas autorizadas de descubrimiento, configuración, vulnerabilidad, registro o seguridad de aplicaciones bajo procedimientos aprobados.

- Calcular la cobertura y las métricas de excepción utilizando la estructura de evaluación oficial.
- Seguimiento de software no compatible, activos no autorizados, problemas de acceso, vulnerabilidades, copias de seguridad fallidas, lagunas de alerta y hallazgos de proveedores a través de la prueba.
- Escribir conclusiones claras sin reclamar autoridad o certeza más allá de las pruebas.

Silencioso** Silencio... TENIDO Marco TENIDO Explicar los 18 Controles, IGs, clases de activos y funciones TENIDO Silencio Inventario Silencio Reconcile dos fuentes independientes y explicar las diferencias TENEDO TENIDO Mostrar insumos, operaciones, medidas, métrica, lista de excepciones y conclusión TENIDO – Alfabetización técnica Silencio Interpret configuración, identidad, escaneo, registro, recuperación y evidencia de aplicación TEN Remediation Silencio Trace finding to owner, due date, correction, and verified retest TEN TEN Comunicación ANTERIGEN Escribe un resumen del administrador de una página y un documento de trabajo detallado – Ética – Utilizar datos sintéticos, autorización, límites de alcance y afirmaciones honestas

27. Laboratorio Ficcional y Portfolio

Un entorno de prácticas seguras utilizando datos sintéticos y sistemas de laboratorio autorizados.

- La regla del laboratorio* Utilizar organizaciones ficticias, datos sintéticos, sistemas aislados y autorización escrita. Nunca ataque objetivos públicos, utilice credenciales reales o publique la producción de herramientas sensibles. Silencio.
1. Crear una compañía ficticia de 50 personas con laptops, servidores, servicios en la nube, una aplicación web, personal remoto y cinco proveedores.
 2. Seleccione IG1 y documente tres adiciones basadas en el riesgo de IG2 o IG3.
 3. Construir inventarios de activos, software, datos, cuenta, sistema de autenticación, red, proveedor, aplicación y fuente de registro.
 4. Use Nmap y osquery en un laboratorio aislado para conciliar los inventarios de activos y software.
 5. Utiliza OpenSCAP o Lynis en un host de laboratorio; conclusiones de configuración de documentos, excepciones, correcciones y reevaluación.
 6. Use Greenbone en los objetivos de laboratorio aprobados; valide la cobertura, los hallazgos, la remediación y la reutilización.
 7. Use Wazuh o Suricata para generar e investigar una alerta de prueba segura.
 8. Use Trivy o ZAP en un repositorio de entrenamiento o aplicación y registre y repita.
 9. Escriba un registro de prueba de copia de seguridad y una tabla de incidentes.

10. Crear cinco documentos de trabajo de evaluación de CIS con insumos, operaciones, medidas, métricas, listas de excepciones y conclusiones.
11. Publicar sólo artefactos sanitarios y afirmar claramente que el proyecto es ficticio y no una evaluación formal CIS.

Silencio **Artifact** Silencio **Lo que prueba** Silencio Silencio... TEN IG selection memo TEN Prioritization and risk reasoning TEN – Reconciliación de los inventarios Silencioso papel de salvaguardia Silencio Estructura de medición oficial y pruebas Reevaluación de la configuración TENIDO Búsqueda técnica, corrección y retestigo TEN Vulnerability report – Cobertura, priorización, excepción y remediación Silencioso Caso de detección Silencio Restaurar prueba Silencioso Disponibilidad y pruebas de recuperación tención Administrador dashboard Silencio Clear risk and action communication

28. Plan de aprendizaje de 30 días

Un calendario centrado para la capacidad útil de nivel inferior.

Días Silencio** Silencio————— TENIDO 1–4 TENIDO Marco, 18 Controles, 153 Salvaguardias, IGs, clases de activos, funciones TENIDO Marco concepto mapa y IG memo ANTE tención 5–8 Silencioso Activos, software, datos, cuentas, acceso Silencio Cuatro inventarios reconciliados TEN 9–12 TENIDO Configuración, vulnerabilidad, email, malware TEN Lab configuración y papel de trabajo de vulnerabilidad Silencio 13–16 Silenciosos Logs, monitoreo, defensa de la red Silencio Mapa fuente de registro y seguro caso de alerta Silencio 17–19 Silencioso recuperación y respuesta a incidentes Silencio Restaurar prueba y registro de mesa Silencio 20–22 Silencio Proveedores y seguridad de aplicaciones Silencio Evaluación del Proveedor y lista de verificación para el desarrollo seguro Silencioso 23–25 Evaluación de la vida Especificación Silencio Cinco medidas de seguridad completas Silencio 26–28 Silencio Laboratorios autorizados de herramientas y remediación TEN 29–30 TENIDO Portfolio y entrevistas TENIDO Portafolio Sanitizado y cinco historias de STAR TEN

29. Preparación de entrevistas
 - Respuestas claras, escenarios prácticos y preguntas para el empleador.*

29.1 ¿Cuáles son los Controles CIS?

Un conjunto priorizado de mejores prácticas defensivas organizadas en 18 Controles y 153 Salvaguardias enfocadas.

29.2 ¿Qué es IG1?

El punto de partida esencial de la higiene cibernética 56-Safeguard que CIS recomienda que cada empresa comience.

29.3 ¿Importa IG1 cada requisito?

Es una base de referencia de priorización. El riesgo material, los contratos, las leyes, los clientes o los servicios críticos pueden requerir salvaguardias adicionales.

29.4 ¿Cómo mide una Salvaguardia?

Utilizar criterios oficiales, dependencias, hipótesis, aportaciones completas, operaciones definidas, medidas, métricas, revisión de procedimientos, excepciones y pruebas.

29.5 ¿Por qué son importantes los inventarios?

Definen a las poblaciones que deben cubrir los controles de configuración, vulnerabilidad, registro, recuperación y respuesta.

29.6 Vulnerability scan versus penetración test?

Un escaneo identifica principalmente debilidades conocidas; la prueba de penetración utiliza el análisis humano calificado y la explotación controlada para evaluar el impacto y la resiliencia.

29.7 ¿Una cartografía de marco demuestra el cumplimiento?

No. Identifica las relaciones, pero la organización debe probar el requisito y la evidencia exacta aplicable.

29.8 ¿Qué puede concluir un analista junior?

Sólo lo que el alcance definido y el soporte de evidencia confiable, con muestreo y limitaciones claramente reveladas.

29.9 Preguntas para hacer al empleador

¿Qué grupo de implementación y adiciones están en alcance?

¿Cómo se crean y reconcilian las poblaciones de inventarios?

¿Qué Salvaguardias tienen la cobertura más incompleta?

¿Cómo se revisan los datos de medición y las excepciones?

¿Qué herramientas de código abierto y comerciales son aprobadas?

¿Cómo se priorizan, financian y prueban los resultados?

¿Cómo revisará el trabajo de los funcionarios superiores?

30. Plantillas, Glosario, Índice y Referencias

- Estructuras de trabajo reutilizables, términos importantes y puntos de partida autorizados.*

30.1 Documentos de trabajo de medición de salvaguardia

Silencio** Silencio. “La Salvaguardia de la Vida” y la IG “Antes” “Escopia y clase de activos” “Principal y sistemas de vida” Las dependencias y las suposiciones de la vida Inputs y validación de la vida “Operaciones en la vida” “Las medidas de la vida” “Metric and interpretation

TENIDO” Excepciones y limitaciones de la vida La acción, el dueño, la fecha y la prueba de la vida

30.2 Finding and retest record

Silencio** Silencio... Los Criterios de la vida siguen adelante. “Acondicionamiento y evidencia de vida” La población afectada está en peligro. “El riesgo y el impacto en la vida” TENIDO Cause TENED

“La protección provisional en la vida” Corrección y propietario de la vida La fecha de su muerte es la siguiente. “El procedimiento de la prueba de mentiras” Resultado final de la vida útil

30.3 Glosario

Silencio** Silencio. Silencio Clase Asset Silencio Categoría afectada por una Salvaguardia, como dispositivos, software, datos, red, usuarios o documentación. Silencio Silencio CIS Benchmark – Recomendaciones de configuración segura para una tecnología específica. tención CIS Control Silencio Una de las 18 amplias áreas defensivas. confidencialidad CIS Salvaguardia Silencio Una acción enfocada y implementable dentro de un Control. – TENCION TENIDA Compartir de la población aplicable en la que se implementa adecuadamente la Salvaguardia. Silencio Silencio IG1 tención 56 salvaguardas esenciales de la higiene cibernética. Silencio IG2 Silencio IG1 más 74 Salvaguardias adicionales. TENIDA IG3 TENIDA IG1 e IG2 más 23 Salvaguardias adicionales; todos 153. TENCION TENIDO Una cuenta, lista, fecha, configuración o resultado producido por operaciones de evaluación. Silencio TENIDO TENIDO Cálculo o interpretación construido a partir de medidas. Silencio Población Silencio Completo conjunto de registros, activos, personas, sistemas o eventos aplicables. tención Revisión de procedimiento tención Evaluación manual de si existe un proceso necesario y contiene los elementos necesarios. Silencio Función de seguridad permanente – Govern, Identificar, Proteger, Detectar, Responder o Recuperar la cartografía.

30.4 Índice de asunto

Subjeto** Silencio... Silenciosos Cuentas Silencio para la seguridad de la aplicación Silencioso inventario de activos Silenciosos registros de auditoría Silencio Protección de datos TENIDO Evidencia y medición TENIDO 4 Silenciosos Grupos de Aplicación Silencio Respuesta del incidente Silencioso analista junior Silencio Silencio Silencio Silencioso Silencioso en la Red 17-18 Silencio Herramientas de código abierto Silencio 24 Silencio pruebas de Penetración Silencioso Silencioso de recuperación proveedores de servicios Silencio 20 Silencio Silencioso Inventario de software TEN TERRITORIO TERRITORIO TERRITORIO TEN TERRITORIO DE Vulnerabilidad ANTE LAS 12

30.5 Referencias oficiales

[](<https://www.cisecurity.org/controls/v8-1> Controles v8.1

Nota de Controles CIS

[](<https://www.cisecurity.org/controls/implementation-groups>)

Seguido

Seguido

Seguido

[]u]CIS Controles cartografías y cumplimiento efectuados/u
título](<https://www.cisecurity.org/cybersecurity-tools/mapping-compliance/mapping-and-compliance-with-the-cis-controls>)

Silencio **Recuerdo final:** Cambio de marcos, mapas, herramientas, productos, amenazas, leyes, contratos y riesgos organizativos. Confirme los recursos oficiales actuales y las obligaciones aplicables antes de una aplicación o evaluación reales. Silencio Respuesta